

Hardering Cookbook

Первое место откуда атакующие пытаются выполнить код /tmp и /var/tmp, именно сюда обычно и попадают шеллы и прочее после нахождения уязвимости. Помешаем в этом, сделаем эти директории noexec.

Монтирование разделов

```
/boot - rw,nodev,noexec,nosuid
/home - rw,nodev,nosuid
/tmp - rw,nodev,noexec,nosuid
/var - rw,nosuid
/var/log - rw,nodev,noexec,nosuid
/var/log/audit - rw,nodev,noexec,nosuid
/var/www - rw,nodev,nosuid
```

в /etc/fstab это должно выглядеть примерно так, в зависимости от первоначальной разметки

```
/dev/mapper/lg_os-lv_root / xfs defaults 1 1
UUID=d73c5d22-75ed-416e-aad2-8c1bb1dfc713 /boot ext4
defaults,nosuid,noexec,nodev 1 2
/dev/mapper/lg_data-lv_home /home xfs defaults 1 2
/dev/mapper/lg_os-lv_tmp /tmp xfs
defaults,nosuid,noexec,nodev 1 2
/dev/mapper/lg_os-lv_var /var xfs defaults,nosuid 1
2
/dev/mapper/lg_os-lv_var_tmp /var/tmp xfs
defaults,nosuid,noexec,nodev 1 2
/dev/mapper/lg_os-lv_var_tmp /var/log xfs
defaults,nosuid,noexec,nodev 1 2
/dev/mapper/lg_os-lv_var_tmp /var/log/audit xfs
defaults,nosuid,noexec,nodev 1 2
/dev/mapper/lg_data-lv_var_www /var/www xfs
defaults,nosuid,noexec,nodev 1 2
/dev/mapper/lg_data-lv_swap swap swap defaults
```

Скроем от лишних глаз /proc

```
vi /etc/fstab proc /proc proc defaults,hidepid=2 0 0
```

Запретим программы с опасным шаблоном применения

```
vi /etc/sysctl.conf
```

Отключаем дампы ядра. Его часто используют в своих целях злоумышленники.

```
fs.suid_dumpable = 0
```

Отключаем функционал системных запросов для дебага (System Request debugging functionality)

```
kernel.sysrq = 0
```

Ограничить доступ к dmesg

```
kernel.dmesg_restrict = 1
```

Защита от атак на переполнение буфера

Randomise memory space (рандомизируем выделенные фрагменты памяти для приложений, так чтобы заранее невозможно было выяснить, на каком участке памяти будет запущено приложение) `kernel.randomize_va_space = 2`

Скрыть kernel pointers (запретить утечку информации об адресном пространстве в пространство пользователя) `kernel.kptr_restrict = 2`

Настроить NTP

```
yum install ntp ntpdate
chkconfig ntpd on
ntpdate pool.ntp.org
/etc/init.d/ntpd start
```

Работа с паролями и учетками

усилим криптографию для хеширования паролей `authconfig --passalgo=sha512 --update`

подтюним политику логинов

`vi /etc/security/pwquality.conf` Тут надо обратить внимание на `minlen`, по умолчанию 9, я бы ставил уже 10-12 `minclass`, по умолчанию не учитывает. Чтобы не мучать пользователей сильно, можно поставить 2-3 `maxrepeat`, по умолчанию выключено. Добавим энтропии! ставим 3 `maxclassrepeat`, с нуля на три

Можно ограничить срок действия пароля

```
vi /etc/login.defs
PASS_MAX_DAYS 90
```

Еще год назад стандарты гласили - меняйте пароли чаще, на сегодняшний день они наконец "догнали", что постоянная смена паролей влияет негативно, как на их сложность, так и на энтропию. Я бы поставил смену раз в год. Раз в год можно и новый пароль придумать, а не менять старый.

Иногда полезно показать при логине не только когда и кто последний раз логинился, но и показать неудачные входы: `vi /etc/pam.d/system-auth session required pam_lastlog.so showfailed`

Также рекомендуется увеличить лимит на использование старых паролей

```
password sufficient pam_unix.so existing_options remember=24
```

Но, если не ставить драконовские `PASS_MAX_DAYS 60`, то в этом нет особой необходимости.

выбрасываем спящих пользователей из системы

```
echo "readonly TMOUT=3600" >> /etc/profile.d/os-security.sh
echo "readonly HISTFILE" >> /etc/profile.d/os-security.sh
```

тюним загрузчик

```
sudo chmod 600 /boot/grub2/grub.cfg
grub2-setpassword
```

(user root)

И закроем single user mode тоже паролем. `/etc/sysconfig/init SINGLE=/sbin/sulogin`

cron

```
echo root > /etc/cron.allow
echo root > /etc/at.allow
rm -f /etc/at.deny /etc/cron.deny
```

тюним настройки sysctl, касающиеся сети

```
vi /etc/sysctl.conf
```

Disable packet forwarding (Обязательно вырубает, если самим нам не надо форвардить трафик через эту машину). По умолчанию переброс трафика с одного интерфейса на другой запрещен.

```
net.ipv4.ip_forward = 0
```

Отключаем прием сообщений о изменении маршрута движения пакетов к хосту (Запрещаем маршрутизацию от источника)

```
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.default.accept_redirects = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.default.send_redirects = 0
net.ipv4.conf.all.secure_redirects = 0
net.ipv4.conf.default.secure_redirects = 0
net.ipv6.conf.all.accept_redirects = 0
net.ipv6.conf.default.accept_redirects = 0
```

защита от IP-спуфинга

```
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.default.accept_source_route = 0
net.ipv6.conf.all.accept_source_route = 0
```

Включить проверку обратного адреса. Все что поступает к нам проходит проверку на соответствие исходящего адреса с нашей таблицей маршрутизации и такая проверка считается успешной, если принятый пакет предполагает передачу ответа через тот же самый интерфейс (Защиты от IP спуфинга)

```
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.lo.rp_filter = 1
net.ipv4.conf.eth0.rp_filter = 1
net.ipv4.conf.default.rp_filter = 1
```

Включить функцию журналирования всех пакетов, которые содержат неправильные (невозможные) адреса

```
net.ipv4.conf.all.log_martians = 1
net.ipv4.conf.default.log_martians = 1
```

Отключим ICMP broadcasts

```
net.ipv4.icmp_echo_ignore_broadcasts = 1
```

Не фиксировать фиктивные ответы в широковещательном диапазоне

```
net.ipv4.icmp_ignore_bogus_error_responses = 1
```

Противодействие SYN flood attacks, отключить отправку syncookies пакетов, если в сокет прилетело слишком много запросов на соединение.

```
net.ipv4.tcp_syncookies = 0
```

Отключить IPv6, если не используется

```
net.ipv6.conf.lo.disable_ipv6 = 1 net.ipv6.conf.all.disable_ipv6 = 1 net.ipv6.conf.default.disable_ipv6 = 1
```

Уменьшим время сохранения сокета в состоянии FIN-WAIT-2 после его закрытия локальной стороной

```
net.ipv4.tcp_fin_timeout = 10
```

```
net.ipv4.tcp_keepalive_time = 1800
net.ipv4.tcp_keepalive_intvl = 15
net.ipv4.tcp_keepalive_probes = 5
```

```
net.ipv4.tcp_synack_retries = 1 # число попыток повтора передачи пакетов SYNACK для пассивных соединений TCP
```

```
net.ipv4.tcp_timestamps = 1 # разрешает временные метки протокола TCP. Их наличие позволяет управлять работой протокола в условиях серьезных нагрузок net.ipv4.ip_local_port_range = 1024 65535 # Запретить маршрутизацию от источника. net.core.somaxconn = 65535 # Не отвечаем на ошибочно сформированные сообщения
```

promiscuous mode

И перепроверим, что интерфейс не работает в promiscuous mode, чтобы на нашей машине невозможно было запустить сниффер: `ip link | grep PROMISC` Отключить если необходимо:

```
ifconfig eth0 -promisc
```

Отключить все TCP wrapper

проверить использует ли tcpwrapper нужный сервис:

```
ldd $(which sshd) | grep libwrap
```

закреть все кроме sshd

```
echo "ALL:ALL" >> /etc/hosts.deny echo "sshd:ALL" >> /etc/hosts.allow
```

iptables

В отдельном файле

syslog

Проверить что syslog работает `systemctl enable rsyslog.service systemctl start rsyslog.service`

Удалить лишние сервисы

Почистить лишние сервисы. В centos7 это `yum remove crontie-anacron`

```
yum remove xinetd
yum remove telnet-server
```

```
yum remove rsh-server
yum remove telnet
yum remove rsh-server
yum remove rsh
yum remove ypbind
yum remove ypserv
yum remove tftp-server
yum remove crone-anacron
yum remove bind
yum remove vsftpd
yum remove httpd
yum remove dovecot
yum remove squid
yum remove net-snmpd
```

Выключаем лишние сервисы

```
systemctl disable xinetd
systemctl disable rexec
systemctl disable rsh
systemctl disable rlogin
systemctl disable ypbind
systemctl disable tftp
systemctl disable certmonger
systemctl disable cgconfig
systemctl disable cgred
systemctl disable cpuspeed
systemctl disable kdump
systemctl disable mdmonitor
systemctl disable messagebus
systemctl disable netconsole
systemctl disable ntpdate
systemctl disable oddjobd
systemctl disable portreserve
systemctl disable qpidd
systemctl disable quota_nld
systemctl disable rdisc
systemctl disable rhnsd
systemctl disable rhsmcertd
systemctl disable saslauthd
systemctl disable smartd
systemctl disable sysstat
systemctl disable atd
systemctl disable nfslock
systemctl disable named
systemctl disable httpd
systemctl disable dovecot
systemctl disable squid
systemctl disable snmpd
```

а некоторые запустить

```
systemctl enable irqbalance # распространение аппаратных прерываний между
процессорам и ядрами системы
systemctl enable psacct
systemctl enable crond
```

Безопасность SSH

```
vi /etc/ssh/sshd_config
HostbasedAuthentication no
PermitRootLogin no
PermitEmptyPasswords no #(!!!!)
PermitUserEnvironment no # отключить применение окружение SSH
Ciphers aes128-ctr,aes192-ctr,aes256-ctr,aes128-cbc,3des-cbc,aes192-cbc,aes256-cbc
```

Сгенерируем ключи:

```
ssh-keygen -b 4096 -t rsa -C "simple" -f ~/.ssh/id_rsa AuthorizedKeysFile .ssh/authorized_keys
```

limits

ram_limits.so - модуль для определения лимитов для пользователей.

конфиг по умолчанию /etc/security/limits.conf

ulimit -a посмотреть текущие лимиты

Правим на это, или где-то рядом

```
soft    nofile    4096
hard    nofile    65536
soft    nproc     4096    # лимиты для открытых файлов и портов (max 1048576)
hard    nproc     4096
soft    locks     4096    # file lock
hard    locks     4096
soft    stack     10240   # размер стека
hard    stack     32768
soft    memlock    64      # лок на память
hard    memlock    64
hard    maxlogins  10
```

Soft limit 32GB, hard 64GB

```
soft  fsize  33554432
hard  fsize  67108864
```

Limits for root

```
root  soft  nofile  4096
root  hard  nofile  65536
root  soft  nproc   4096
root  hard  nproc   4096
root  soft  stack   10240
root  hard  stack   32768
root  soft  fsize   33554432
```

Заменяем баннер:

```
/etc/issue
/etc/issue.net
```

Установим историю побольше:

```
/etc/profile HISTSIZE=5000
```

rkhunter

```
yum install epel-release
yum install rkhunter
rkhunter --update
rkhunter --propupd
```

Arpwatch #####